QUESTION 2: DETECTION ACCURACY METRICS

True Positive, False Positive, True Negative & False Negative

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** Alert Classification & Detection Accuracy

1. EXPLAINING THE FOUR CORE METRICS

In Security Operations, detection tools (like SIEM or EDR) generate alerts based on rules. Every alert or non-alert condition falls into one of four evaluation categories based on whether a threat actually exists and whether the tool triggered an alarm:

True Positive (TP): The detection system triggered an alert for suspicious activity, and after investigation, the activity is confirmed to be an actual malicious attack or policy breach. **False Positive (FP):** The detection system triggered an alert, but investigation reveals the activity was completely harmless, legitimate user behavior, or a system misconfiguration. **True Negative (TN):** Normal, benign system activity occurs, and the security tool correctly generates no alert. The system is operating normally and remains secure. **False Negative (FN):** A real security attack or breach occurs on the network, but the detection system fails to trigger any alert, leaving the security team unaware of the incident.

2. METRICS COMPARISON MATRIX

Metric	Simple Definition	Operational Impact	Realistic Cybersecurity Example
True Positive (TP) Real Threat Detected	Alert triggered, attack is real.	Requires immediate containment and escalation.	EDR triggers on `mimikatz.exe`. L1 analyst verifies attacker is dumping credentials.
False Positive (FP) False Alarm	Alert triggered, but activity is benign.	Wastes analyst time, causes alert fatigue, requires rule tuning.	SIEM triggers "Port Scan", but it is an authorized Nessus vulnerability scan by internal IT.
True Negative (TN) Normal Operation	No alert triggered, no threat exists.	Optimal security state. Tools monitor silently.	An employee logs in during business hours from an office IP; system logs event with zero alerts.
False Negative (FN) Silent Breach	No alert triggered, but active attack occurred.	Most dangerous outcome. Leads to unnoticed breach and data theft.	Attacker uses custom malware compiled seconds ago; antivirus rule set fails to flag payload.

3. WHY FPS AND FNS MATTER IN SECURITY MONITORING

3.1 The Danger of False Positives (FPs)

While False Positives do not directly mean a system is compromised, a high FP rate severely damages SOC efficiency:

Alert Fatigue & Analyst Burnout: When 90% of daily alerts are false alarms, analysts become desensitized. They may begin skimming through tickets or making hasty assumptions, increasing the risk of missing a real attack hidden in the noise. **Wasted Operational Time:** Analysts spend valuable hours verifying harmless scripts, IT maintenance tasks, or misconfigured software instead of hunting real threats. **Need for Rule Tuning:** High FP rates indicate that SIEM detection rules are too broad and require fine-tuning or exclusion parameters.

3.2 The Lethal Threat of False Negatives (FNs)

False Negatives represent the worst-case scenario for any cybersecurity team:

Undetected Adversary Dwell Time: Attackers can maintain persistent access, move laterally across internal servers, and exfiltrate confidential data for months without detection. **Catastrophic Impact:** FNs often lead to major public security incidents, such as enterprise-wide ransomware deployment or massive data breaches.

4. PRACTICAL SOC ANALYST SCENARIOS

Scenario A: Resolving a False Positive

Alert: "Unusual Admin Creation" on Host-DB02.

Investigation: L1 analyst checks ticket queue, finds an approved Jira Change Request for DB maintenance. Sysadmin confirmed creating temp account `admin_temp` during maintenance window.

Action: Classified as **False Positive**. Closed with verification notes and documented for detection rule whitelist updating.

Scenario B: Identifying a True Positive

Alert: "Encoded PowerShell Execution" on HR-PC-12.

Investigation: L1 decodes Base64 command, revealing an automatic download script pulling an `.exe` payload from a suspicious external IP. EDR shows command launched by an unapproved email attachment.

Action: Classified as **True Positive**. Immediate host isolation and escalation to Tier 2 Incident Response.

5. KEY TERMINOLOGY & REFERENCES

Alert Fatigue: Operational numbness caused by excessive false positive alerts. **Dwell Time:** The duration an attacker remains unnoticed inside a victim environment.

References:
• NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide: **https://csrc.nist.gov/**
• MITRE ATT&CK Framework Evaluation Metrics: **https://attack.mitre.org/**